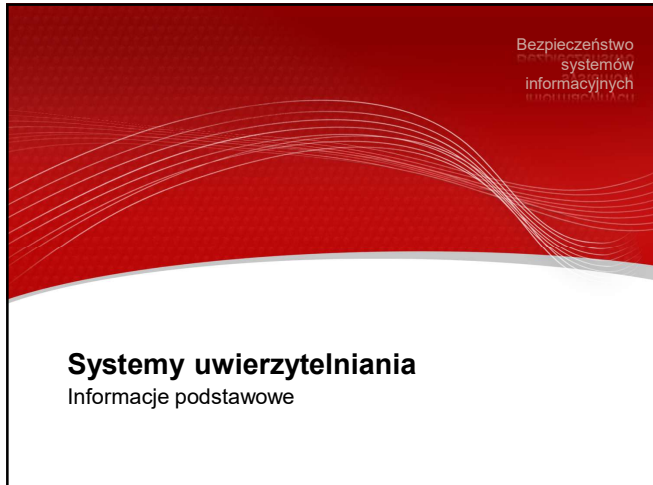




139

Systemy uwierzytelniania - podstawy

Bezpieczeństwo systemów informacyjnych

- ❑ Określane są często jako systemy AAA, gdyż zazwyczaj realizują operacje:
 - ✓ **Authentication** (uwierzytelnienie) – potwierdzenie tożsamości. Podczas logowania się do systemu uwierzytelniamy się przedstawiając mu dowody swojej tożsamości (*credentials*) np. w postaci nazwy użytkownika i hasła.
 - ✓ **Authorization** (autoryzacja) – potwierdzenie uprawnień użytkownika lub uprawnienie użytkownika do zrobienia czegoś w systemie (np. do skorzystania z drukarki sieciowej).
 - ✓ **Accounting** (rozliczanie, billing) – czynności związane z rejestrowaniem aktywności użytkownika (np. czasu pracy, ilości przesłanych danych).

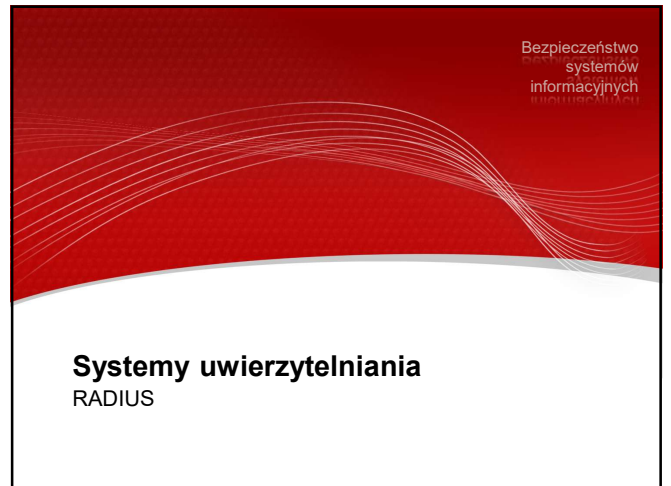
140

Systemy uwierzytelniania - podstawy

Bezpieczeństwo systemów informacyjnych

- ❑ Często pozwalają na realizację funkcji pojedynczego logowania SSO (*Single Sign-On*).
- ❑ Użytkownik podaje wówczas swoją nazwę i hasło tylko raz na początku swojej sesji, po czym jest automatycznie logowany we wszystkich zasobach w danym systemie.

141



142

RADIUS

Bezpieczeństwo systemów informacyjnych

- ❑ RADIUS (RFC 2865) został zaprojektowany w dobie wczesnego Internetu jako system do uwierzytelniania użytkowników wdzwanianych.
- ❑ **RADIUS = Remote Authenticated Dial-In User Service**
- ❑ Centralna baza danych zawiera dane wszystkich użytkowników oraz ograniczenia nakładane na każde konto użytkownika.
- ❑ Pracuje na portach UDP 1812 (uwierzytelnianie) oraz 1813 (billing), używane były także 1645/46
- ❑ Może korzystać z różnych protokołów uwierzytelniania (bezpośrednio np. PAP, CHAP lub poprzez EAP – *Extensible Authentication Protocol*)

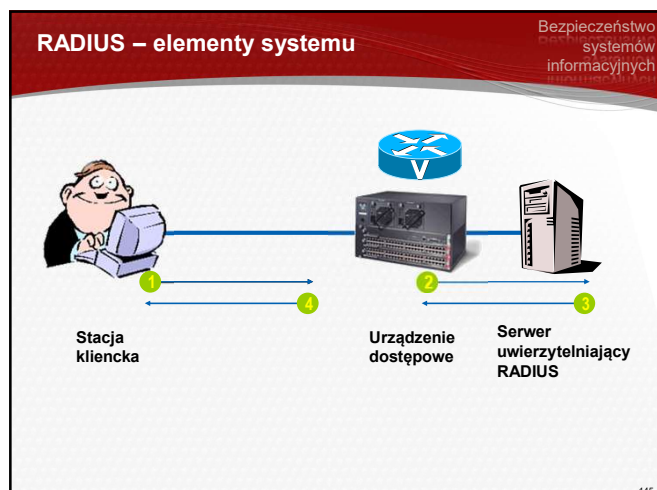
143

RADIUS – elementy systemu

Bezpieczeństwo systemów informacyjnych

- ❑ Klient – urządzenie lub użytkownik łączący się z dostawcą usług.
- ❑ Serwer dostępu sieciowego (*Network Access Server, NAS*) – przetwarza żądania połączenia i inicjuje z klientem wymianę danych połączenia. W wyniku działania tej usługi ustalona zostaje nazwa użytkownika, hasło, rodzaj zasobu itd. Następnie NAS wysyła te informacje do serwera RADIUS w celu uwierzytelnienia.
- ❑ Serwer RADIUS – porównuje informacje przesłane przez NAS z danymi zapisanymi w bazie i zwraca informacje uwierzytelniające i autoryzujące. Realizuje też zapis informacji bilingowych.

144



145

- ## RADIUS – rodzaje komunikatów
- ❑ Wysyłane do serwera RADIUS
 - ✓ **Access Request**
 - ❖ Wysyłana przez klienta RADIUS: zawiera żądanie uwierzytelnienia i autoryzacji próby połączenia
 - ✓ **Accounting Request**
 - ❖ Wysyłana przez klienta RADIUS w celu poinformowania serwera rozliczającego o rozpoczęciu, wstrzymaniu, zakończeniu połączenia

146

- ## RADIUS – rodzaje komunikatów
- ❑ Wysyłane przez serwer RADIUS
 - ✓ **Access Accept**
 - ✓ **Access Reject**
 - ✓ **Access Challenge**
 - ❖ Jest to żądanie podania dodatkowych informacji, które może być wysłane przez serwer usługi RADIUS w odpowiedzi na wiadomość Access-Request dla niektórych metod uwierzytelniania.
 - ✓ **Accounting Response**
 - ❖ Wysyłana przez klienta RADIUS w celu poinformowania serwera rozliczającego o rozpoczęciu, wstrzymaniu, zakończeniu połączenia

147

- ## RADIUS
- ❑ Przesyłane hasła są zamieniane na skrót wyliczony algorytmem MD5 na połączeniu hasła i tajnego ciągu współdzielonego przez NAS i RADIUS
 - ✓ Ze względu na MD5 nie jest to silne zabezpieczenie i (zwłaszcza w komunikacji poza siecią lokalną) powinno być stosowane np. z dodatkowym tunelowaniem komunikatów RADIUS poprzez SSL lub z bezpiecznymi metodami uwierzytelniania zawartymi w EAP.

148

- ## RADIUS – format komunikatu
- ❑ Standard RADIUS opisuje komunikację pomiędzy NAS, a serwerem uwierzytelniającym
 - ❑ Do transportu komunikatów RADIUS używany jest protokół UDP
- | | | |
|--------------------|--------|---------|
| op_code (1) | id (1) | len (2) |
| authenticator (16) | | |
| atrybuty (...) | | |
- ❑ op_code – kod operacji (Access-Request itd.)
 - ❑ id – identyfikator zapytania
 - ❑ len – długość komunikatu (min. 20, max. 4096)

149

- ## RADIUS – format komunikatu c.d.
- | | | |
|--------------------|--------|---------|
| op_code (1) | id (1) | len (2) |
| authenticator (16) | | |
| atrybuty (...) | | |
- ❑ authenticator – kod uwierzytelniający zapytanie lub odpowiedź
 - ✓ dla komunikatu typu response jest to:

$$\text{ResponseAuth} = \text{MD5}(\text{op_code} + \text{id} + \text{len} + \text{request_auth} + \text{attributes} + \text{secret})$$
 - ❑ atrybuty – pole o zmiennej długości zawierające informacje charakterystyczne dla realizowanej operacji w postaci listy par (nazwa, wartość)

150

RADIUS – wybrane implementacje

Bezpieczeństwo
systemów
informacyjnych

- ❑ FreeRADIUS – bezpłatna implementacja dla systemów bazujących na Unix/Linux
 - ✓ <http://www.freeradius.org>
- ❑ Cisco Secure ACS (*Access Control Server*)
- ❑ W systemach Windows Server serwer RADIUS jest zawarty w usłudze IAS (*Internet Authentication Service*)

151

151

Inne rozwiązania dla zdalnego dostępu

Bezpieczeństwo
systemów
informacyjnych

- ❑ TACACS oraz TACACS+
 - ✓ Terminal Access Controller Access Control System
 - ✓ System zbliżony do RADIUS
 - ✓ Rozwiązanie firmowe (*proprietary*) Cisco
- ❑ Oddzwanianie

152

152

Systemy uwierzytelniania

802.1x – uwierzytelnianie na porcie

Bezpieczeństwo
systemów
informacyjnych

153

802.1x – informacje podstawowe

Bezpieczeństwo
systemów
informacyjnych

- ❑ Jest to standard opracowany przez IEEE i określany „kontrola dostępu na poziomie portu”
 - ✓ Umożliwia uwierzytelnienie użytkownika na poziomie warstwy łącza danych
 - ✓ Urządzenia sieciowe (np. przełączniki LAN lub punkty dostępowe Wi-Fi) przyznają dostęp korzystając z wyniku uwierzytelnienia wykonanego przez zewnętrzny serwer uwierzytelniający
 - ✓ Serwer uwierzytelniający może pracować w różnych standardach (bardzo często jest to RADIUS)
- ❑ 802.1x bazuje na protokole EAP (*Extensible Authentication Protocol*, RFC 2284)
 - ✓ Można spotkać określenie 802.1x jako *EAP over LAN* (EAPOL)

154

154

802.1x – informacje podstawowe

Bezpieczeństwo
systemów
informacyjnych

- ❑ Standard 802.1x zaprojektowany został z myślą o sieciach przewodowych, ale obecnie jest też bardzo często używany w sieciach bezprzewodowych
- ❑ 802.1x wykonuje uwierzytelnienie związane z danym portem urządzenia
 - ✓ Dostępne są zarówno urządzenia mogące wykonać tylko jedno uwierzytelnienie na danym porcie, jak też i wiele uwierzytelnień
 - ✓ Port nie przekazuje danych użytkownika do sieci dopóki połączenie nie zostanie uwierzytelnione
 - Dla uwierzytelnionych użytkowników mogą być zastosowane określone wcześniej zasady dostępu (np. pasmo, QoS)
 - Nieuwierzytelnieni użytkownicy mogą być przyłączeni do wydzielonej dla gości sieci VLAN
 - ✓ W przypadku sieci bezprzewodowych określenie port może być rozumiane jako pojedyncze stowarzyszenie klienta z punktem dostępowym

155

155

802.1x – funkcje systemu

Bezpieczeństwo
systemów
informacyjnych

- ❑ Uwierzytelnienie (*Authentication*)
 - ✓ Określenie czy użytkownik ma prawo dostępu do sieci lub usług
- ❑ Autoryzacja (*Authorization*)
 - ✓ Określenie do czego dany użytkownik jest uprawniony
- ❑ Kontrola dostępu (*Access Control*)
 - ✓ Realizacja dostępu i uprawnień wynikających z uwierzytelnienia i autoryzacji
- ❑ Egzekwowanie zasad (*Policy enforcement*)
- ❑ Połączenie uwierzytelnienia, autoryzacji i kontroli dostępu w celu wdrożenia określonych zasad

156

156

802.1x – elementy systemu

Bezpieczeństwo
systemów
informatycznych

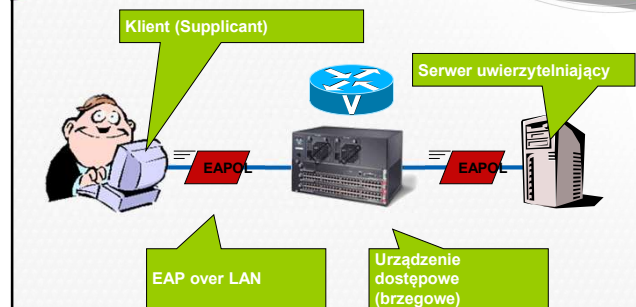
- ❑ Klient (*Supplicant*) – stacja użytkownika
 - ✓ Komputer PC, Laptop, Tablet, Smartfon
 - ✓ Musi mieć zaimplementowany protokół EAP zgodny z drugą stroną połączenia
- ❑ Sieciowe urządzenia dostępowe (*Authenticator*)
 - ✓ W typowym przypadku jest to przełącznik LAN lub punkt dostępowy sieci bezprzewodowej
 - ✓ Wymusza on uwierzytelnienie klienta przed udostępnieniem mu portu LAN
- ❑ Serwer uwierzytelniający (AAA)
 - ✓ Dokonuje uwierzytelnienia klienta na żądanie urządzenia granicznego
 - ✓ Standard 802.1x nie specyfikuje protokołu dla serwera uwierzytelniającego. Zazwyczaj jest to RADIUS

157

157

802.1x – elementy systemu

Bezpieczeństwo
systemów
informatycznych



158

158

802.1x – sterowanie dostępem

Bezpieczeństwo
systemów
informatycznych

- ❑ Przed wykonaniem autoryzacji użytkownika urządzenie brzegowe przyjmuje jedynie ramki z protokołem EAPOL (Typ=0x888E)
- ❑ Poprawne uwierzytelnienie użytkownika przydziela mu dostęp do warstwy drugiej i dotyczy wszystkich protokołów warstw wyższych (np. IP, IPX, TCP, UDP, SPX)
- ❑ W przypadku braku uwierzytelnienia użytkownik nie ma dostępu do sieci lub może być mu przydzielony dostęp do specjalnej sieci VLAN dla nieautoryzowanych użytkowników

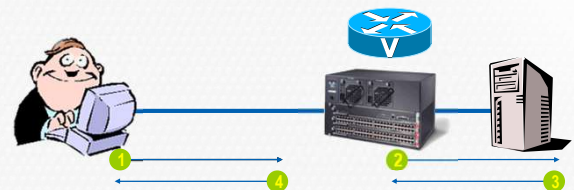
159

159

802.1x – sterowanie dostępem

Bezpieczeństwo
systemów
informatycznych

802.1x stanowi system kontroli dostępu do sieci LAN bazujący na modelu klient-serwer



- 1 Użytkownik aktywuje łącze do sieci (np. włączając swój PC)
- 2 Przełącznik odpytuje SU czy dany użytkownik ma prawo dostępu do sieci
- 3 Serwer uwierzytelniający zwraca odpowiedź
- 4 W zależności od wyniku uwierzytelnienia przełącznik otwiera (lub nie) dany port dla ruchu użytkownika

160

160

802.1x – porty logiczne

Bezpieczeństwo
systemów
informatycznych

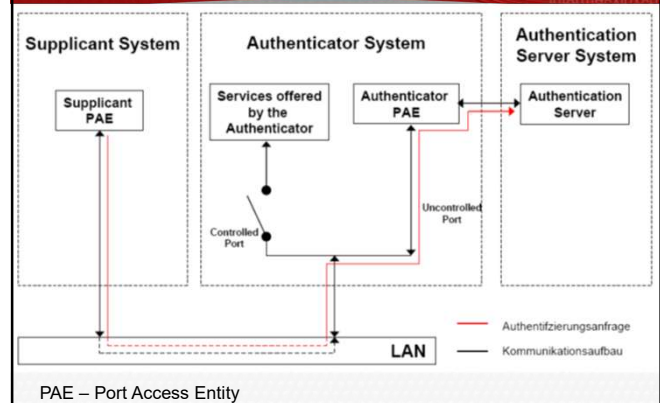
- ❑ Według standardu IEEE 802.1x dla danego portu fizycznego urządzenia brzegowego przypisywane są dwa rodzaje portów logicznych:
 - ✓ Port niekontrolowany – ścieżka tylko dla ruchu EAPOL
 - ✓ Port kontrolowany – służy do komunikacji użytkownika z siecią po pomyślnym uwierzytelnieniu. Przed uwierzytelnieniem port kontrolowany jest zamknięty.

161

161

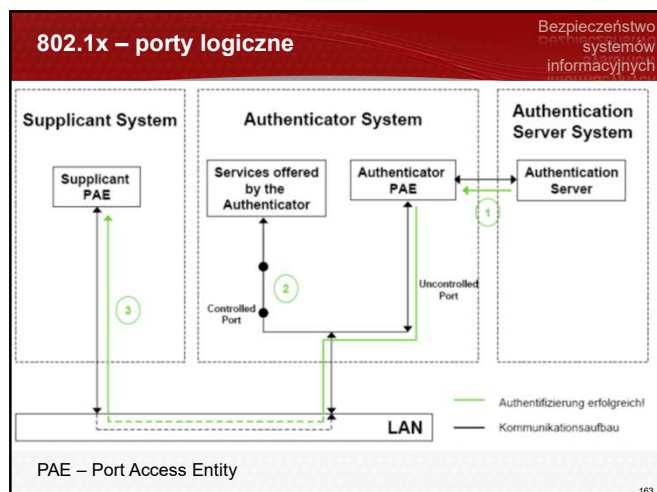
802.1x – porty logiczne

Bezpieczeństwo
systemów
informatycznych

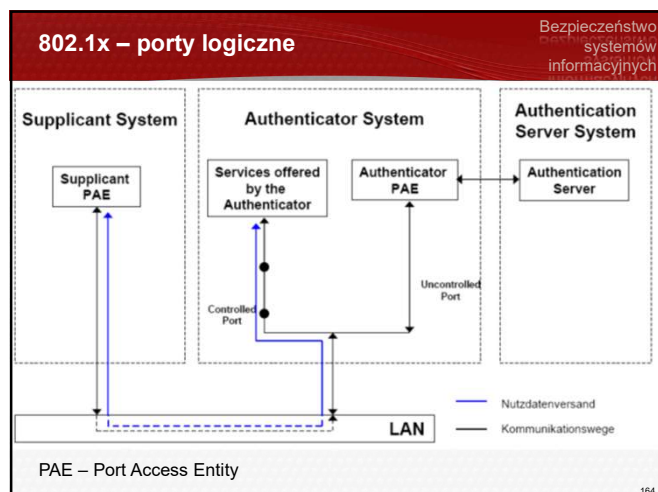


162

162



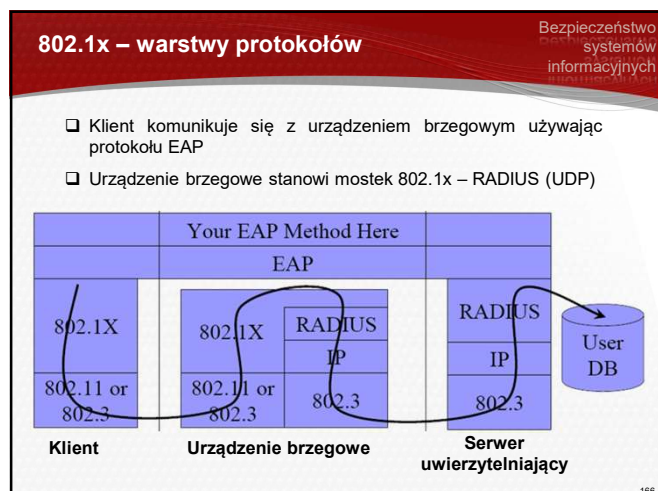
163



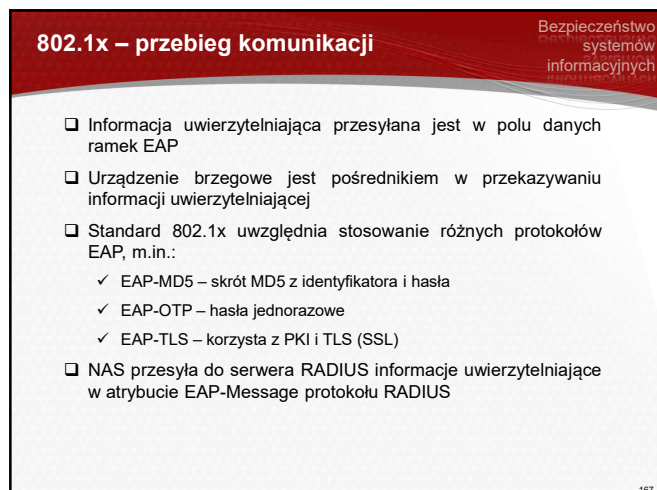
164



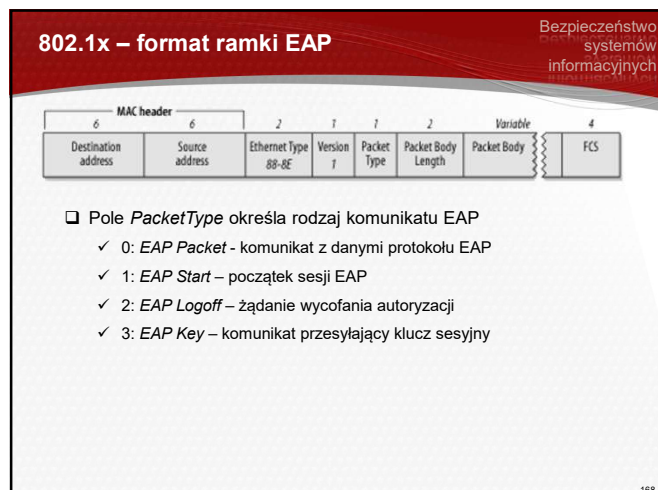
165



166



167



168

169

170

171

172

173

174

Bezpieczeństwo systemów informacyjnych

- 179

Bezpieczeństwo systemów informacyjnych

- 176

Bezpieczeństwo systemów informacyjnych

177

Bezpieczeństwo systemów informacyjnych

- 178

Bezpieczeństwo systemów informacyjnych

- 430

Bezpieczeństwo systemów informacyjnych

190

7

MS CHAP

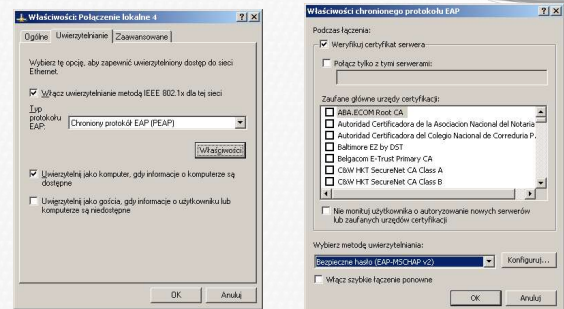
Bezpieczeństwo
systemów
informatycznych

- ❑ MS CHAP – Microsoft CHAP (v1 i v2)
- ❑ Jako tajne hasło używany jest skrót MD4 wyznaczony od właściwego hasła
- ❑ MS CHAP v1 nie ma formatu EAP i używany jest tylko w trybie TTLS
- ❑ MS CHAP v2 może być używane zarówno poprzez TTLS jak i PEAP

181

Konfiguracja 802.1x w Windows

Bezpieczeństwo
systemów
informatycznych

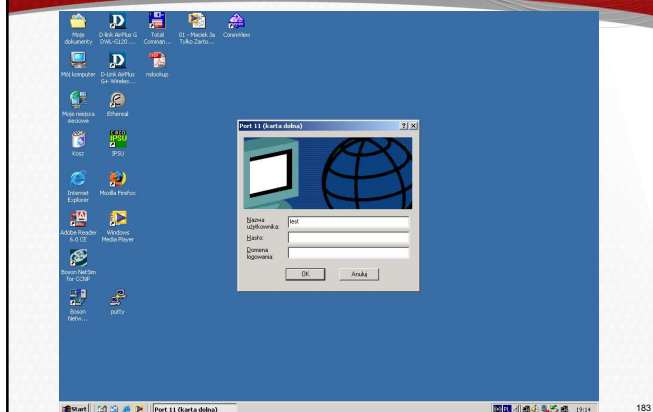


- ✓ W systemach Windows XP SP3 i następnych (np. Vista, 7, 8) obecność zakładki „Uwierzytelnianie” uzależniona jest od działania odpowiedniej usługi systemowej.

182

Konfiguracja 802.1x w Windows

Bezpieczeństwo
systemów
informatycznych



183